

Password Policies

Now that we have worked through numerous ways to capture credentials and passwords, let us cover some best practices related to passwords and identity protection. Speed limits and traffic laws exist so that we drive safely. Without them, driving would be chaos. The same happens when a company does not have proper policies in place; everyone would be able to do whatever they want without consequences. That is why service providers and administrators use different policies and apply methods to enforce them for better security.

Let us meet Mark, a new employee for Inlanefreight Corp. Mark, does not work in IT, and he is not aware of the risk of a weak password. He needs to set his password for his business email. He picks the password `password123`. However, he gets an error saying that the password does not meet the company password policy and a message that lets him know the minimum requirement for the password to be more secure.

In this example, we have two essential pieces, a definition of the password policy and the enforcement. The definition is a guideline, and the enforcement is the technology used to make the users comply with the policy. Both aspects of the password policy implementation are essential. During this lesson, we will explore both and understand how we can create an effective password policy and its implementation.

Password Policy

A [password policy](#) is a set of rules designed to enhance computer security by encouraging users to employ strong passwords and use them adequately based on the company's definition. The scope of a password policy is not limited to the password minimum requirements but the whole life cycle of a password (such as manipulation, storage, and transmission).

Password Policy Standards

Because of compliance and best practices, many companies use [IT security standards](#). Although complying with a standard does not mean that we are 100% secure, it is a common practice within the industry that defines a baseline of security controls for organizations. That should not be the only way to measure the effectiveness of the organizational security controls.

Some security standards include a section for password policies or password guidelines. Here is a list of the most common:

1. [NIST SP800-63B](#)
2. [CIS Password Policy Guide](#)
3. [PCI DSS](#)

We can use those standards to understand different perspectives of password policies. After that, we can use this information to create our password policy. Let us take a use case where different standards use a different approach, `password expiration`.

`Change your password periodically (e.g., 90 days) to be more secure` may be a phrase we heard a couple of times, but the truth is that not every company is using this policy. Some companies only require their users to change their passwords when there is evidence of compromise. If we look at some of the above standards, some require users to change the password periodically, and others do not. We should stop and think, challenge the standards and define what is best for our needs.

Password Policy Recommendations

Let us create a sample password policy to illustrate some important things to keep in mind while creating a password policy. Our sample password policy indicates that all passwords should:

- Minimum of 8 characters.
- Include uppercase and lowercase letters.
- Include at least one number.
- Include at least one special character.
- It should not be the username.
- It should be changed every 60 days.

Our new employee, Mark, who got an error when creating the email with the password `password123`, now picks the following password `InLaneFreight01!` and successfully registers his account. Although this password complies with company policies, it is not secure and easily guessable because it uses the company name as part of the password. We learned in the "Password Mutations" section that this is a common practice of employees, and attackers are aware of this.

Once this password reaches the expiration time, Mark can change 01 to 02, and his password complies with the company password policy, but the password is nearly the same. Because of this, security professionals have an open discussion about password expiration and when to require a user to change their password.

Based on this example, we must include, as part of our password policies, some blacklisted words, which include, but are not limited to:

- Company's name
- Common words associated with the company
- Names of months
- Names of seasons
- Variations on the word welcome and password
- Common and guessable words such as password, 123456, and abcde

Enforcing Password Policy

A password policy is a guide that defines how we should create, manipulate and store passwords in the organization. To apply this guide, we need to enforce it, using the technology at our disposal or acquiring what needs to make this work. Most applications and identity managers provide methods to apply our password policy.

For example, if we use Active Directory for authentication, we need to configure an [Active Directory Password Policy GPO](#), to enforce our users to comply with our password policy.

Once the technical aspect is covered, we need to communicate the policy to the company and create processes and procedures to guarantee that our password policy is applied everywhere.

Creating a Good password

Creating a good password can be easy. Let's use [PasswordMonster](#), a website that helps us test how strong our passwords are, and [1Password Password Generator](#), another website to generate secure passwords.

Take the Password Test

Tip: Avoid sequences or repeated characters in your passwords

Show password: ☒

CjDC2x[U

Very Strong

8 characters containing: Lower caseUpper caseNumbersSymbols

Time to crack your password:
1 thousand years

cjDC2x[U was the password generated by the tool, and it is a good password. It would take a long time to crack and would likely not be guessed or obtained in a password spraying attack, but it is tough to remember.

We can create good passwords with ordinary words, phrases, and even songs that we like. Here is an example of a good password This is my secure password or The name of my dog is Poppy. We can combine those passwords with special characters to make them more complex, like ()The name of my dog is Poppy!. Although hard to guess, we should keep in mind that attackers can use OSINT to learn about us, and we should keep this in mind when creating passwords.

Take the Password Test

Tip: Avoid sequences or repeated characters in your passwordsShow password: ☒

The name of my dog is Popy

Very Strong

26 characters containing: Lower caseUpper caseNumbersSymbols

Time to crack your password:
381 trillion years

With this method, we can create and memorize 3, 4, or more passwords, but as the list increases, it will be difficult to remember all of our passwords. In the next section, we will discuss using a Password Manager to help us create and maintain the large number of passwords we have.

← Previous

Next →

+10 Streak pts

✔ Mark Complete & Next

Cheat Sheet

Resources

Table of Contents

Introduction

Theory of Protection	✔
Credential Storage	✔
John The Ripper	✔

Remote Password Attacks

 Network Services	
 Password Mutations	
 Password Reuse / Default Passwords	
Windows Local Password Attacks	
 Attacking SAM	
 Attacking LSASS	
 Attacking Active Directory & NTDS.dit	
 Credential Hunting in Windows	
Linux Local Password Attacks	
 Credential Hunting in Linux	
 Passwd, Shadow & Opasswd	
Windows Lateral Movement	
 Pass the Hash (PtH)	
 Pass the Ticket (PtT) from Windows	
 Pass the Ticket (PtT) from Linux	
Cracking Files	
 Protected Files	
 Protected Archives	
Password Management	
Password Policies	
Password Managers	
Skills Assessment	
 Password Attacks Lab - Easy	
 Password Attacks Lab - Medium	
 Password Attacks Lab - Hard	

My Workstation

OFFLINE

 Start Instance

∞ / 1 spawns left